

SSH certificate encoding/parsing incompatibility with OpenSSH #9207

Closed

#9207

lkubb opened on Jul 10, 2023 · edited by lkubb

Edits Contributor ...

Description

There is an encoding mismatch regarding critical options with values between `ssh-keygen` and `cryptography` :

1. Loading an SSH certificate generated by `ssh-keygen` with `cryptography` does not yield expected values.
2. Reading an SSH certificates generated by `SSHCertificateBuilder` with `ssh-keygen` fails.

Steps

Re 1:

1. Generate a key to be signed: `ssh-keygen -t ed25519`
2. Generate a CA signing key: `ssh-keygen -t ecdsa`
3. Sign a certificate: `ssh-keygen -s id_ed25519 -n cryptouser, testuser -I test@cryptography.io -O "critical:force-command=echo aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa" -O "critical:verify-required" -V 0x63b2b264:0x767eb5c0 id_ecdsa.pub`
4. Load the certificate with `cryptography` :

```
from cryptography.hazmat.primitives.serialization import (  
    load_ssh_public_identity,  
)
```

```
cert = load_ssh_public_identity(  
    b"ecdsa-sha2-nistp256-cert-v01@openssh.com AAAAKGVjZHNhLXNoYTItbW"  
    b"lzdHAYNTYtY2VydC12MDFAb3BlbnZaC5jb20AAAAGLfsFv9Gbc6LZSiJFWdYQ1"  
    b"IMNI50GEXw0fBpgGVf+Y4AAAAIbmlzdHAYNTYAAABBBizVyRgVLR4F38bIOLBN"  
    b"8CNm8Nf+eBHCvkKDKb9WdyLLD61CEmzjK/ORwFuSE4N60eIGbFidBf0D0xh7G6o"  
    b"TNxsAAAAAAAAAAAAAEAAAAUdGVzdEBjcmlwdG9ncmFwaHkuaw8AAAAaAAAAACm"  
    b"NyeXB0b3VzZXIAAAAIIdGVzdHVzZXIAAAAY7KyZAAAAAB2frXAAAAAwwAAAA1mb"  
    b"3JjZS1jb21tYW5kAAAAALAAACHlY2hvIGFhYWFhYWFhYWFhYWFhYWFhYWFhYWFh"  
    b"YWZhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFhYWFh"  
    b"pdC1YMTetZm9yd2FyZGludG9ncmFwaHkuaw8AAAAAAXcGVybWl0LWFnZW50LWZvcndhcmRpbm"  
    b"CAAAAAAAAFnBlcm1pdC1wb3J0LWZvcndhcmRpbmcAAAAAAACnBlcm1pdC1wd"  
    b"HkAAAAAAADnBlcm1pdC1lc2VyaXJjAAAAAAAZAAAAAC3NzaC1lZDI1"  
    b"NTE5AAAAICH6csE0mGb0FT2B/S/FJg3uyPsaPSZUZk2SVYlfs0KLAAAAUwAAAAA"  
    b"zc2gtZWQyNTUxOQAAEDz2u7X5/TFbN7Ms7DP4yArhz1oWYkKdAk7FGfKHfjtY"  
    b"/YfNQ80ky3dCZri7PnSzScEEjos7723dhF8/y99wwH"  
)
```

```
print(cert.critical_options[b"force-command"])
assert cert.critical_options == {
    b"force-command": b"echo aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa",
    b"verify-required": b"",
}
```

```
b'\x00\x00\x00(echo aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa'
Traceback (most recent call last):
  File "/home/user/test.py", line 21, in <module>
    assert cert.critical_options == {b"force-command": b"echo aaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
AssertionError
```

Re 2:

1. Generate an SSH certificate with `cryptography`

```
from datetime import datetime, timedelta

from cryptography.hazmat.primitives.asymmetric import ed25519
from cryptography.hazmat.primitives.serialization import (
    SSHCertificateBuilder,
    SSHCertificateType,
)

ca_key = ed25519.Ed25519PrivateKey.generate()
sign_key = ed25519.Ed25519PrivateKey.generate()

cert = (
    SSHCertificateBuilder()
    .public_key(sign_key.public_key())
    .type(SSHCertificateType.USER)
    .valid_for_all_principals()
    .valid_before((datetime.now() + timedelta(days=1)).timestamp())
    .valid_after(datetime.now().timestamp())
    .add_critical_option(
        b"force-command", b"echo aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa"
    )
    .sign(ca_key)
)

with open("/tmp/sshcert.pub", "wb") as f:
    f.write(cert.public_bytes())
```

2. Try to read it using `ssh-keygen`

```
$ cat /tmp/sshcert.pub
ssh-ed25519-cert-v01@openssh.com AAAAIHNzaC1lZDI1NTE5LWN1cnQtdjAxQG9wZW5zc2guY29tAAAAICUJE
$ ssh-keygen -Lf /tmp/sshcert.pub
/tmp/sshcert.pub:
  Type: ssh-ed25519-cert-v01@openssh.com user certificate
  Public key: ED25519-CERT SHA256:0xx00zve78LqnyWIf3DRrbIzVoWXDK/FuBRerotDrHY
  Signing CA: ED25519 SHA256:HHnlyz4SqRKncKwUVgN3hvJyKA8BQ5Hmy0S0sjgfnGQ (using ssh-ed
  Key ID: ""
  Serial: 0
  Valid: from 2023-07-10T12:31:27 to 2023-07-11T12:31:27
  Principals: (none)
```

Critical Options:
show_options: parse critical: string is too large

Background

The [specification](#) is a bit confusing in regards to how critical options/extensions with values should be encoded:

The critical options section of the certificate specifies zero or more options on the certificates validity. The format of this field is a sequence of zero or more tuples:

string	name
string	data



So that's the first header for the data. You then have to look at the table to determine the format of data's contents. E.g.

force-command string Specifies a command that is executed
...

So, for name=force-command, the contents of the data buffer are a string. That's the second header.

The intent is to support options/extensions with data types other than string, e.g. integers or arrays of string.

Source

golang/crypto had the same issue: [golang/go#10569](#)

lkubb added a commit that references this issue [on Jul 10, 2023](#)

Add tests for issue [pyca#9207](#)

Verified 7ff431e

lkubb mentioned this [on Jul 10, 2023](#)

[Fix encoding of SSH certs with critical options #9208](#)

reaperhulk closed this as [completed](#) in [#9208](#) [on Jul 11, 2023](#)

reaperhulk added a commit that references this issue [on Jul 11, 2023](#)

Fix encoding of SSH certs with critical options ([#9208](#)) ...

Verified 1ca7adc

reaperhulk on Jul 11, 2023 · edited by reaperhulk

Edits ▾ Member ...

A few more steps before we close this:

- Backport to 41.0.x with warning for parsing the incorrect encoding ([Backport ssh cert fix #9211](#))
- Changelog entry to 42 stating we've dropped support (concurrent with forward porting the 41.0.2 changelog)



reaperhulk reopened this [on Jul 11, 2023](#)



reaperhulk added a commit that references this issue [on Jul 11, 2023](#)

Fix encoding of SSH certs with critical options ([pyca#9208](#)) ...

e068c6f



alex added a commit that references this issue [on Jul 11, 2023](#)

Backport ssh cert fix ([#9211](#)) ...

Verified e190ef1

reaperhulk on Jul 11, 2023

Member ...

Okay this is now released in 41.0.2 😊

♥ 1



reaperhulk closed this as [completed](#) [on Jul 11, 2023](#)



GoVulnBot mentioned this [on Jul 15, 2023](#)

✓ [x/vulndb: potential Go vuln in github.com/pyca/cryptography: CVE-2023-38325](#)
[golang/vulndb#1920](#)



s0undt3ch added 4 commits that reference this issue [on Jul 16, 2023](#)

Bump to `cryptography==41.0.2` to address [GHSA-cf7p-gm2m-833m](#) ...

Unverified e512e79

Bump to `cryptography==41.0.2` to address [GHSA-cf7p-gm2m-833m](#) ...

Unverified 560e4ed

Bump to `cryptography==41.0.2` to address [GHSA-cf7p-gm2m-833m](#) ...

Unverified 0a9def0

Bump to `cryptography==41.0.2` to address [GHSA-cf7p-gm2m-833m](#) ...

Unverified 28b052c



garethgreenaway added a commit that references this issue [on Jul 17, 2023](#)

Bump to `cryptography==41.0.2` to address [GHSA-cf7p-gm2m-833m](#) ...

5b2e752

michael-cfchan on Jul 29, 2023

...

Is it correct that this issue affects cryptography>=40.0? The patched code appears to be introduced only in 40.0. Thanks!

alex on Jul 29, 2023 via email

Member ...

Yes. It should be noted that contrary to what's in the CVE, this isn't a security issue, its just a bug.

...

♥ 2



zenmonkeykstop mentioned this in 2 pull requests [on Aug 17, 2023](#)

 [Add ignore for safety alert #59473 freedomofpress/securedrop#6920](#)

 [added exclude for 59473 freedomofpress/fpf-security-allowlists#18](#)



 **Shortfinga** added a commit that references this issue [on Aug 21, 2023](#)

Fix affected version in PYSEC-2023-112 

2143d8a



 **Shortfinga** mentioned this [on Aug 21, 2023](#)

 [Fix affected version in PYSEC-2023-112 pypa/advisory-database#145](#)



 **sethmlarson** added a commit that references this issue [on Aug 22, 2023](#)

Fix affected version in PYSEC-2023-112 

Verified

904accb



 **Shilpi-J** mentioned this [on Sep 5, 2023](#)

 [Need clarity regarding cryptography vulnerability affect on paramiko paramiko/paramiko#2297](#)



 **Shilpi-J** mentioned this [on Sep 28, 2023](#)

 [Update README.md ansible-collections/ibm.storage_virtualize#16](#)



 **github-actions** locked as resolved and limited conversation to collaborators [on Oct 28, 2023](#)

Sign up for free to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode



 **Fix encoding of SSH certs with critical options**
pyca/cryptography

Participants

